

Policy and Compliance Documentation

Prepared by: Omkar Sawant

Client: GlobalTech Corp

Date: 1 June 2026

Project: Implementing a Secure Network Architecture for a Large Enterprise

Organisation: Spinnaker Analytics

1. Purpose and Scope

- This document defines the comprehensive security policies for GlobalTech Corp's network and data protection, and maps the implemented security architecture against relevant regulatory requirements.
- It covers network access policies, data protection policies, acceptable use, and compliance with GDPR and HIPAA.
- These policies govern all employees, contractors, and third parties who access GlobalTech Corp's systems, data, or network
 - across all locations including HQ Mumbai, Remote Office 1 (Delhi), Remote Office 2 (Bangalore), and remote employees.

2. Network Access Policy

2.1 General Access Requirements

- All access to the GlobalTech Corp network requires authentication via Entra ID with MFA enforced
 - no single-factor access is permitted
- Network access is granted on a least-privilege basis
 - users are assigned to VLANs and roles that match their job function only
- Unmanaged or non-compliant devices are denied access to the corporate network and redirected to the remediation VLAN
- All network access is logged and subject to monitoring
 - users have no expectation of privacy on corporate network resources
- Sharing of network credentials
 - VPN certificates
 - or session tokens is strictly prohibited

2.2 Remote Access Policy

- Remote access is permitted only via the approved VPN (WireGuard / SSL VPN)
 - direct access to internal resources from the internet is blocked
- Full tunnel VPN is mandatory
 - split tunnelling is not permitted under any circumstances
- Remote employees must ensure their working environment is secure
 - no access from public Wi-Fi without VPN active
- VPN sessions are limited to 8 hours
 - re-authentication required after expiry
- Devices used for remote access must pass all compliance checks
 - EDR active
 - OS patched
 - disk encrypted

2.3 Guest and Third-Party Access

- Guest users are restricted to the Guest VLAN (internet-only)
 - no access to internal resources
- Third-party contractors requiring internal access must be sponsored by a GlobalTech employee and approved by IT Security
- Contractor accounts are time-limited
 - automatically expire at the end of the engagement period
- Third-party access is restricted to only the specific systems required for their engagement

3. Data Protection Policy

3.1 Data Classification

Classification	Description	Examples	Handling requirements
Public	Information approved for public release	Marketing materials, press releases	No restrictions
Internal	General business information	Policies, procedures, project plans	Internal distribution only
Confidential	Sensitive business information	Financial reports, contracts, strategies	Encrypted, access controlled
Restricted	Highest sensitivity — regulatory or personal data	PII, salary data, health records, credentials	Encrypted, strict RBAC, audit logged

3.2 Data Handling Requirements

- Restricted and Confidential data must be encrypted in transit (TLS 1.3) and at rest (AES-256) at all times
- Restricted data must not be stored on personal devices
 - personal cloud storage
 - or unmanaged endpoints
- Data transfers outside the organisation require prior approval from the data owner and IT Security
- Printed copies of Restricted data must be securely disposed of using cross-cut shredding
- Data must not be retained longer than necessary
 - retention periods defined in the Data Retention Schedule

3.3 Data Breach Notification

- Any suspected or confirmed data breach must be reported to the IT Security team within 1 hour of discovery
- The IT Security team will conduct initial assessment within 2 hours to determine scope and severity
- If personal data is involved,
 - GDPR breach notification to the supervisory authority is required within 72 hours of becoming aware
- Affected individuals must be notified without undue delay if the breach is likely to result in high risk to their rights

4. Acceptable Use Policy

4.1 Permitted Use

- Corporate systems and network resources are provided for business purposes
 - limited personal use is permitted provided it does not interfere with business operations
- Employees may use corporate devices for incidental personal browsing during non-work hours
- Use of approved collaboration tools (Microsoft Teams, SharePoint) for business communication is encouraged

4.2 Prohibited Use

- Accessing, downloading, or distributing illegal, offensive, or inappropriate content using corporate systems
- Installing unauthorised software, browser extensions, or plugins on corporate devices
- Attempting to circumvent security controls including firewalls, content filters, MFA, or endpoint protection
- Using corporate network or devices for cryptocurrency mining, running personal servers, or commercial activities
- Connecting personal devices directly to the corporate network (User or Server VLAN) without IT Security approval
- Sharing, publishing, or transmitting Confidential or Restricted data to unauthorised recipients

4.3 Consequences of Policy Violation

- Minor violations:
 - verbal or written warning
 - mandatory security awareness training
- Serious violations:
 - suspension of system access pending investigation
 - formal disciplinary action
- Severe violations (deliberate data theft, sabotage):
 - immediate termination and potential legal action

5. GDPR Compliance

5.1 GDPR Overview

- GlobalTech Corp processes personal data of employees and customers, including data subjects in the European Union.
- The General Data Protection Regulation (GDPR) requires lawful, fair, and transparent processing of personal data with appropriate technical and organisational measures to ensure security.

5.2 GDPR Compliance Checklist

	Requirement	Control implemented	Status
Art. 5	Lawful basis for processing personal data documented	Data processing register maintained by Legal	✓ Compliant
Art. 13/14	Privacy notices provided to data subjects	Privacy policy published, updated Jan 2026	✓ Compliant
Art. 17	Right to erasure — personal data deleted on request	MDM remote wipe, data deletion procedure defined	✓ Compliant
Art. 25	Data protection by design and by default	Encryption at rest and in transit, least privilege RBAC	✓ Compliant
Art. 32	Technical and organisational security measures	Full security architecture — all 10 deliverables	✓ Compliant
Art. 33	Breach notification to supervisory authority within 72 hours	Incident response plan includes GDPR notification procedure	✓ Compliant
Art. 35	DPIA for high-risk processing activities	DPIA conducted for HR and Finance data processing	✓ Compliant
Art. 37	Data Protection Officer appointed where required	DPO appointed — contact: dpo@globaltech.com	✓ Compliant

5.3 Personal Data Controls

- Personal data stored in Finance/HR VLAN
 - AES-256 encryption at rest, strict RBAC, access logged to SIEM
- Data minimisation enforced
 - only personal data necessary for the stated purpose is collected and retained
- Data subject access requests (DSAR) fulfilled within 30 days
 - process defined in Data Subject Rights Procedure
- International data transfers to non-EEA countries use Standard Contractual Clauses (SCCs)

6. HIPAA Compliance

6.1 HIPAA Overview

- Where GlobalTech Corp processes Protected Health Information (PHI) on behalf of healthcare clients, the Health Insurance Portability and Accountability Act (HIPAA) Security Rule requires administrative, physical, and technical safeguards to protect ePHI (electronic PHI).

6.2 HIPAA Security Rule Compliance Checklist

Safeguard	Requirement	Control implemented
Administrative — Access control	Unique user IDs, emergency access, automatic logoff, encryption	Entra ID unique accounts, MFA, 5-min screen lock, TLS 1.3
Administrative — Audit controls	Record and examine activity in systems containing ePHI	SIEM logging all access to PHI systems, 2-year retention
Administrative — Workforce training	Security awareness training for all staff handling ePHI	Annual mandatory training + phishing simulation
Physical — Workstation use	Policies on workstation use and physical access controls	Clear desk policy, screen privacy filters, locked server room
Technical — Encryption	Encrypt ePHI in transit and at rest	TLS 1.3 in transit, AES-256 at rest on all PHI storage
Technical — Integrity	Protect ePHI from improper alteration or destruction	FIM via Wazuh, database TDE, backup encryption
Technical — Transmission security	Guard against unauthorised access to ePHI in transit	TLS 1.3 enforced, VPN for remote access, email encryption
Breach notification	Notify affected individuals and HHS within 60 days	IR plan includes HIPAA breach notification procedure

7. Policy Review and Governance

Policy	Owner	Review frequency
Network Access Policy	IT Security Manager	Annual + after any major incident
Data Protection Policy	Data Protection Officer	Annual + on regulatory change
Acceptable Use Policy	HR Director + IT Security	Annual
GDPR Compliance Checklist	Data Protection Officer	Annual + on regulatory change
HIPAA Compliance Checklist	Compliance Manager	Annual + on regulatory change
All security policies	CISO	Annual — approved by board

8. Summary

- This document establishes the policy and compliance framework for GlobalTech Corp's secure network architecture. The following are in place:
 - Network access policy
 - least privilege
 - MFA mandatory
 - remote access via VPN only
 - guest isolation
 - Data classification
 - 4-tier classification with handling requirements per level
 - Data protection policy
 - encryption mandatory for Restricted/Confidential
 - breach notification within 1 hour internally and 72 hours for GDPR
 - Acceptable use policy
 - permitted and prohibited use defined
 - consequences for violations
 - GDPR compliance
 - 8 articles mapped to implemented controls
 - DPO appointed
 - HIPAA compliance
 - 8 safeguards mapped to implemented controls
 - Policy governance
 - owners assigned
 - annual review cycle
 - CISO board approval